Vikas R

192311353

CSE

ITA1409-ETHICAL HACKING

CO2-AT1

Nmap Network Scan Analysis (20 Marks)

Introduction

Nmap (Network Mapper) is a network scanning tool used to identify open ports, running services, service versions, and operating systems. The scan of target IP address 192.168.1.10 identified HTTP (80), SSH (22), and MySQL (3306).

Security Risks of Identified Services

Port	Service	Security risks
80	HTTP	Unencrypted communication may expose passwords, session cookies, and sensitive information.
22	SSH	Weak passwords, outdated software, or misconfigurations may allow unauthorized access.
3306	MySQL	Unauthorized database access may expose, modify, or delete sensitive information.

How attackers could exploit these services

1. HTTP (Port 80): Attackers may intercept unencrypted traffic, exploit vulnerable web applications, or use SQL injection and other application vulnerabilities to access data.
2. SSH (Port 22): Attackers may attempt password guessing, use stolen credentials, or exploit known vulnerabilities in outdated SSH software.

3. MySQL (Port 3306): Attackers may attempt to access the database using weak credentials, exploit vulnerable versions, or abuse excessive database privileges.
4. Operating system and service versions: Attackers may use this information to identify known vulnerabilities and select suitable attack methods.

Recommended Security Measures

- HTTP security: Use HTTPS with valid TLS certificates and redirect HTTP traffic to HTTPS.
- SSH security: Use SSH keys instead of passwords where possible, disable direct root login, and restrict access to trusted IP addresses.
- MySQL security: Do not expose port 3306 publicly; allow access only from authorized application servers and use strong passwords.
- Patch management: Regularly update the operating system, web server, SSH service, and MySQL database.
- Firewall configuration: Allow only required ports and block unnecessary inbound connections.
- Access control: Apply the principle of least privilege to user and database accounts.
- Monitoring: Review logs and use intrusion detection systems to identify suspicious activity.
- Regular testing: Conduct authorized vulnerability assessments and penetration tests.

Conclusion

The Nmap report reveals potential risks related to unencrypted communication, unauthorized remote access, and database exposure. Proper patching, firewall rules, strong authentication, and continuous monitoring can reduce these risks and improve network security.

2. Phishing Awareness Campaign Analysis (20 Marks)

Introduction

GoPhish is a tool used to conduct authorized phishing simulations and measure employee awareness of social engineering attacks. The campaign at ABC Technologies Pvt. Ltd. revealed that employees are vulnerable to phishing emails and malicious attachments.

Analysis of the Report

Finding	Percentage or observation	Security weakness
Clicked phishing link	40%	Employees may not verify suspicious links before clicking.

Entered login credentials	20%	Employees may not recognize fraudulent login pages.
Downloaded malicious attachment	Several users	Employees may not identify suspicious or unexpected files.

These findings indicate a need for stronger security awareness, improved email protection, and better reporting procedures.

Security Weaknesses Demonstrated

1. Lack of awareness: Employees may not recognize suspicious emails or common phishing techniques.
2. Poor link verification: Users may click unfamiliar links without checking the sender or destination.
3. Credential exposure: Employees may enter passwords on fraudulent websites.
4. Unsafe attachment handling: Downloading suspicious attachments may expose company devices to malware.
5. Insufficient reporting: Employees may not know how to report suspected phishing attempts quickly.

Recommended User Awareness Programs

- Regular training: Conduct cybersecurity awareness sessions covering phishing, spoofing, and social engineering.
- Phishing simulations: Use authorized simulations to help employees recognize suspicious messages.
- Link verification: Train employees to check sender addresses, URLs, and unexpected requests.
- Attachment safety: Teach employees not to open unexpected attachments or enable macros without verification.
- Incident reporting: Provide a simple method for reporting suspicious emails to the IT security team.
- Periodic assessments: Measure phishing simulation results and provide additional training to employees who need it.

Recommended Email Security Controls

1. Spam filters: Block suspicious and unwanted emails.
2. SPF: Helps receiving mail servers verify which servers are authorized to send email for a domain.
3. DKIM: Uses digital signatures to help verify email integrity and domain association.
4. DMARC: Defines how receiving servers should handle messages that fail SPF/DKIM-based domain authentication checks.

5. Multi-factor authentication (MFA): Adds another verification factor if a password is stolen.
6. Endpoint protection: Detects and blocks malware delivered through malicious attachments.
7. Safe link and attachment scanning: Identifies suspicious URLs and files before employees interact with them.
8. Least privilege: Limits the damage possible if an employee account or device is compromised.

Recommended Organizational Policies

- Establish a clear email and internet usage policy.
- Require employees to report suspicious messages immediately.
- Prohibit sharing passwords or entering credentials on unverified websites.
- Establish an incident response procedure for phishing and malware infections.
- Provide prompt password resets and revoke compromised sessions when necessary.
- Review campaign metrics regularly and improve training based on results.

Conclusion

The campaign shows that phishing is a significant organizational risk. Regular employee training, strong email authentication, MFA, endpoint protection, and clear reporting procedures can reduce the likelihood and impact of successful phishing attacks.

3. DNS Zone Transfer (AXFR) Analysis (10 Marks)

Introduction

DNS (Domain Name System) translates domain names into IP addresses and stores information about domain services. The `dig` tool is used to query DNS records and assess DNS configuration. A successful AXFR (Authoritative Zone Transfer) indicates that the DNS server allows a requester to retrieve a copy of the DNS zone.

Security Implications

A successful unauthorized zone transfer may expose:

- Internal hostnames and server names.
- Mail server records, such as MX records.
- IP addresses associated with DNS records.
- Subdomain names and service locations.
- Other DNS records that may reveal the organization's network structure.

How Attackers Could Exploit the Information

1. Reconnaissance: Identify servers, subdomains, and network services.
2. Target selection: Identify potentially sensitive systems, such as mail servers and administrative hosts.
3. Vulnerability identification: Research exposed services and software versions for known weaknesses.
4. Phishing preparation: Use discovered hostnames and mail infrastructure details to create more convincing targeted attacks.
5. Further attacks: Attempt to exploit identified systems if additional vulnerabilities or misconfigurations exist.

A successful zone transfer does not itself grant access to the listed servers, but it can make reconnaissance easier.

Recommended Security Measures

- Restrict AXFR: Allow zone transfers only to explicitly authorized secondary DNS servers.
- Use ACLs: Configure access control lists to limit which IP addresses can request transfers.
- Use TSIG: Authenticate zone transfers with Transaction Signature (TSIG) keys.
- Review DNS records: Remove unnecessary, outdated, or sensitive internal records from externally accessible zones.
- Separate DNS infrastructure: Use split-horizon DNS to keep internal records separate from public DNS records where appropriate.
- Monitor DNS activity: Log and investigate unexpected zone-transfer requests.
- Regular testing: Use authorized DNS assessments to identify misconfigurations and verify access restrictions.

Conclusion

An unrestricted DNS zone transfer can reveal valuable information about an organization's infrastructure and help attackers plan further attacks. Restricting AXFR, authenticating transfers, separating internal and external DNS, and monitoring DNS activity are essential security measures.